

Dossier Bloc 2 RNCP39583 — Alcide

Concevoir et développer des applications logicielles

Version candidate déployée : 0.13.0-rc.3 — 2026-07-20

Statut : **CI/CD, production et recette authentifiée desktop validées ; audit humain RGAA et mobile authentifié encore à exécuter**

1. Cadre officiel et règle de validation

Le présent dossier répond au référentiel RNCP39583 et non à une grille interne au projet. L'épreuve demande le code source, la documentation associée et un dossier écrit de 30 pages maximum. Les pièces attendues couvrent notamment CI, CD, architecture, prototype, tests unitaires, sécurité, accessibilité, versions, recette, correction des bogues et trois manuels d'exploitation.

Le bloc comporte neuf compétences. Il faut en acquérir au moins cinq et les quatre compétences éliminatoires doivent toutes être acquises :

- C2.2.1 — prototype ;
- C2.2.2 — harnais de tests unitaires couvrant la majorité du code développé ;
- C2.2.3 — logiciel évolutif, sécurisé, accessible et conforme ;
- C2.3.1 — cahier de recettes couvrant l'ensemble des fonctionnalités attendues.

Il n'existe pas de « seuil RNCP de 70 % ». Les seuils Vitest sont des gates de projet ; la réponse à C2.2.2 doit s'appuyer sur le périmètre réellement instrumenté et sur la représentativité des tests.

2. Synthèse de la version candidate

Compétence	État de la version candidate	Condition de fermeture
C2.1.1	Environnements décrits	rapport de performance final et preuves datées
C2.1.2	CI du SHA applicatif 3a21e3b verte	aucune sur le périmètre automatisé
C2.2.1	Prototype 0.13.0 - rc.3 déployé ; parcours publics et authentifiés desktop vérifiés	recette authentifiée mobile et utilisateur autonome
C2.2.2	Tests API/Web/PostgreSQL exécutés localement et en CI ; shared non isolé	archiver les rapports bruts de couverture du SHA déposé
C2.2.3	Revue OWASP, audit des dépendances, axe public et interactions authentifiées réalisés	audit RGAA humain complet
C2.2.4	Merge, migration, CD et smoke tests du SHA applicatif réussis	tag du gel documentaire final
C2.3.1	Recettes publiques automatisées exécutées	recettes authentifiées et validation humaine
C2.3.2	Registre enrichi avec les défauts réellement découverts et tests de non-régression liés	clôture des réserves issues de la recette humaine
C2.4.1	Manuels présents ; procédures non validées depuis un clone vierge	test depuis un clone vierge et paquet final

Cette table ne préjuge pas de la décision du jury. Elle distingue volontairement le code écrit d'une preuve d'exécution effectivement obtenue.

3. C2.1.1 — Environnements, qualité et performance

Environnement de développement et de test

Élément	Choix du projet	Vérification
Gestion de sources	Git et dépôt GitHub	branche, SHA, historique, PR/CI
Gestion monorepo	pnpm workspace	<code>pnpm install --frozen-lockfile</code>
Runtime de référence	Node.js 24 LTS en local, CI, conteneurs et Vercel	<code>node --version</code>
Compilateur	TypeScript 5.7 via <code>tsc</code>	<code>pnpm typecheck</code> , <code>pnpm build</code>
Serveur Web	Next.js 15 App Router	<code>build</code> et <code>healthcheck</code> Web
Serveur API	Hono sur Node.js	tests routes et <code>health/readiness</code> API
Base	PostgreSQL 16, Drizzle ORM	migrations et tests d'intégration
Tests	Vitest, Testing Library, Playwright, axe	rapports API, Web et navigateur
Conteneurs	Docker multi-stage et Compose	<code>build</code> , <code>migration/seed</code> , <code>healthchecks</code>
Production	Vercel Web/API et Neon PostgreSQL	déploiement et smoke tests

Le candidat doit ajouter dans la version remise le nom et la version de l'éditeur effectivement utilisé. Le présent audit a été réalisé sous Windows, PowerShell et Codex desktop ; cette information ne doit pas être remplacée par un éditeur fictif.

Gates qualité visées

La liste ci-dessous décrit les conditions de fermeture. Les contrôles publics et la contre-recette authentifiée ont été exécutés sur le SHA applicatif `3a21e3b2b547e99410388d5b83b62df79a436ea8`. B2-A25 distingue les anomalies reproduites sur `rc.2` de leur validation finale sur `rc.3` :

- aucune erreur ESLint ;
- aucune erreur TypeScript ;
- tests API et Web réussis, contrats shared exercés et périmètre shared explicitement documenté ;
- rapport de couverture API et Web conservé sans exclusions opportunistes ;
- build de production réussi sous Node 24 ;
- audit bloquant dès le niveau low ;
- Playwright public réussi ; recette authentifiée manuelle réussie, suite `storageState` encore à exécuter ;
- build Docker et procédure de migration/seed exécutables.

Performance

Un simple HTTP 200 ne constitue pas une mesure de performance. La preuve finale doit au minimum conserver : durée build/CI, latence des healthchecks, durée des générations IA, timeout observé, taille des pages ou Web Vitals et résultat d'un petit test de charge sur les routes sans coût IA. Les objectifs doivent être reliés à l'usage : navigation réactive, absence de 504 et retour d'erreur clair avant la limite Vercel.

Une première mesure locale réelle est consignée dans B2-A21 : sur 50 requêtes séquentielles, le p95 observé est de 8,18 ms pour `/health` et 36,35 ms pour `/health/ready`. Elle couvre PostgreSQL local, mais ni Vercel/Neon ni OpenAI, et ne remplace donc pas la mesure du SHA final en production.

4. C2.1.2 — Intégration continue

Le protocole cible est :

1. checkout du SHA ;
2. installation figée par lockfile ;
3. build du package partagé ;
4. lint et typecheck ;
5. tests et couverture API/Web ;
6. build des packages ;
7. tests Playwright et accessibilité ;
8. audit de dépendances bloquant dès le niveau low ;
9. build des images Docker ;
10. migration Drizzle bloquante après une CI verte sur main ;
11. déploiement API puis Web, avec smoke tests, seulement si la migration réussit.

Le workflow CD manuel qui permettait de contourner la CI est supprimé de la version candidate. Le déploiement reste conditionné par la variable de projet et par un `workflow_run` réussi. `deploy-api` dépend de `migrate-db`, puis `deploy-web` dépend de `deploy-api`. La preuve réelle finale est la CI 29747228594 puis la CD 29747592571, toutes deux réussies. Pour le même SHA, les builds Git de production ont été annulés et une seule production GitHub Actions a abouti par projet.

5. Architecture maintenable

Navigateur

- > Next.js Server Components / Server Actions
- > API Hono protégée par secret interservice et identité utilisateur
- > controllers -> services métier -> repositories
- > PostgreSQL / OpenAI

Les contrats partagés sont placés dans packages/shared. Les entrées HTTP et les sorties IA sont validées par Zod. Les accès aux ressources sont contrôlés avec l'identité de l'utilisateur. Les corrections de cette version introduisent notamment une couche service pour les journaux de séance afin de ne plus faire porter l'ownership au seul contrôleur.

Écarts architecturaux restant à suivre : duplication de certains schémas d'entrée entre API et shared, observabilité fondée sur console.* et rate limit mémoire non distribué.

6. C2.2.1 — Prototype et besoins couverts

Le prototype vise un utilisateur sportif authentifié et couvre les user stories suivantes :

ID	Besoin attendu	Parcours
US-01	Se connecter et protéger les données personnelles	OAuth Google, routes privées
US-02	Générer une séance adaptée	/generate puis détail
US-03	Générer un programme multi-semaines cohérent	/programs/generate puis détail
US-04	Retrouver et filtrer ses séances/programmes	listes, filtres, pagination
US-05	Exécuter une séance avec pause/reprise	Timer
US-06	Journaliser effort, feedback et douleur éventuelle	fin de séance
US-07	Suivre sa progression	dashboard
US-08	Choisir le modèle OpenAI autorisé	settings
US-09	Supprimer une ressource avec confirmation	dialogues accessibles
US-10	Utiliser les parcours au clavier et sur mobile	audit RGAA représentatif

Le prototype de référence <https://ai-sport-web.vercel.app> sert la version 0.13.0-rc.3. Les healthchecks Web et API, la readiness PostgreSQL/IA, la session privée, les créations/suppressions métier, le Timer, le dashboard, les paramètres et la déconnexion ont été contrôlés après le déploiement du SHA applicatif 3a21e3b2b547e99410388d5b83b62df79a436ea8 (B2-A25).

7. C2.2.2 — Harnais de tests unitaires

Le harnais comprend :

- tests des schémas et invariants métier partagés ;
- tests des services IA, erreurs, retry et timeout global ;
- tests controllers et validation UUID ;
- tests d'ownership pour workout, programme et journaux ;
- tests Web de logique, composants et erreurs utilisateur ;
- tests d'intégration PostgreSQL ou preuve explicitement séparée ;
- tests Playwright, qui complètent mais ne remplacent pas les unitaires.

Les rapports API et Web sont publiés séparément. La mesure locale du 2026-07-20 sur la candidate 0.13.0-rc.1 donne :

Rapport	Statements	Branches	Functions	Lines	Périmètre/exclusions
API unitaire	84,97 %	80,40 %	95,38 %	84,97 %	src, hors bootstrap, DB, repositories et routes déclaratives ; repositories mesurés séparément en intégration PostgreSQL
API intégration PostgreSQL	93,69 %	80 %	100 %	93,69 %	repositories et service d'ownership inclus par <code>vi test.integration.config.ts</code> ; 8 tests réels sur PostgreSQL 16.14
Web	68,07 %	77,45 %	79,38 %	68,07 %	app, composants, lib ; les pages serveur non instanciées apparaissent bien à 0 %
Shared	Non isolé	Non isolé	Non isolé	Non isolé	schémas exercés par 6 tests de contrats API, mais pas de rapport instrumenté autonome

Les suites locales de 0.13.0-rc.3 comptent 155 tests API et 43 tests Web réussis. Un PostgreSQL 16.14 réel a également exécuté 8/8 tests d'intégration sur la candidate locale 69b21ef-dirty, preuve séparée consignée dans B2-A19. Le job PostgreSQL, les tests Playwright publics et axe ont ensuite réussi sur le SHA applicatif final dans la CI 29747228594. Les rapports bruts de couverture du SHA déposé ne sont pas archivés et les cas Playwright ne sont pas comptés comme tests unitaires.

Le nombre de tests ou un pourcentage API isolé ne suffit pas. Cette mesure montre une majorité sur les périmètres instrumentés, avec une faiblesse visible sur plusieurs pages serveur Web. La clôture C2.2.2 reste donc conditionnée au run CI du SHA final et à l'archivage de tous les rapports bruts.

8. C2.2.3 — Conformité fonctionnelle, sécurité et accessibilité

Conformité fonctionnelle

Les sorties IA ne sont plus acceptées uniquement parce que le JSON est valide. Les schémas et services vérifient les invariants utiles : durée, structure, numérotation et quantité de semaines/séances. Les cas force/répétitions et les tolérances retenues doivent rester couverts par des tests métier.

Le Timer mesure le temps actif et non le temps mural incluant les pauses. Les erreurs réseau ne sont plus transformées silencieusement en fausses 404 ou en paramètres prétendument enregistrés.

Sécurité OWASP Top 10

La revue détaillée se trouve dans docs/security/owasp-review.md. Les preuves ne doivent pas réduire l'OWASP Top 10 à npnm audit. Les points centraux sont :

- contrôle d'accès et ownership de chaque ressource liée ;
- secrets utilisés dans les modules serveur ; l'absence dans les bundles et le réseau de la candidate déployée reste à vérifier ;
- requêtes Drizzle paramétrées ;
- validation des entrées et des IDs ;
- timeout global inférieur à la limite de la fonction ;
- configuration CSP/CORS/headers ;
- audit de dépendances bloquant ;
- intégrité de la CI et versions d'outils figées ;
- logs/monitoring et traitement des incidents ;
- URL OpenAI fixe pour prévenir la SSRF.

Les risques résiduels, notamment rate limit mémoire et absence de SIEM, sont présentés comme tels et non comme des contrôles complets.

Accessibilité

Le référentiel choisi est le RGAA 4.1.2, fondé sur WCAG 2.1 A/AA. Le choix, l'échantillon et la méthode figurent dans docs/rncp/bloc2-accessibilite-rgaa.md.

La recette instrumentée locale B2-A20 a réussi 12/12 contrôles sur Chromium et 12/12 sur Firefox. Elle couvre quatre pages publiques à 320 px, axe ciblé, console et erreurs JavaScript, le lien d'évitement, le nom du bouton Google et quatre redirections sans session. Elle a conduit à corriger deux défauts de focus/nom accessible et un contraste visuellement faible. Après déploiement, la redirection /dashboard vers /login, le lien d'évitement et le démarrage OAuth jusqu'au formulaire Google ont aussi été observés sur 0.13.0-rc.2. B2-A25 ajoute une session authentifiée réelle : formulaires, création séance et programme, Timer, onglets, suppressions, dashboard, paramètres et déconnexion. Cette recette a découvert quatre anomalies, corrigées et contre-recettées sur 0.13.0-rc.3. Les contrôles humains complets — zoom, ratios de contraste, lecteur d'écran et mobile authentifié — restent à consigner. Le statut « conforme RGAA » reste interdit tant que l'audit humain final n'est pas terminé.

9. C2.2.4 — Version, déploiement et viabilité

La séquence technique de 0.13.0-rc.3 est tracée : merge sur main, gates CI, SHA immuable, migration, déploiement de ce SHA puis healthchecks et démarrage OAuth. Le tag v0.13.0-rc.3 identifie le gel documentaire final qui contient ce dossier et son PDF. La session obtenue par le candidat et les parcours métier authentifiés sont consignés dans B2-A25 ; l'inspection interne de la session et le test d'utilisation autonome restent hors des preuves acquises.

Le changelog identifie 0.13.0-rc.3 comme préversion datée. Les anciens domaines alcide-* ne sont plus des cibles de production.

10. C2.3.1 — Cahier de recettes

Le cahier de recettes est `docs/bloc2/cahier-recettes.md`. Son inventaire couvre les familles fonctionnelles identifiées : authentification, séances, programmes, listes, détail, suppression, Timer, journaux, dashboard, paramètres, sécurité, accessibilité, healthchecks, CI/CD et déploiement.

Pour chaque cas, il distingue :

- attendu ;
- obtenu ;
- environnement et date ;
- exécution manuelle, automatique ou inspection ;
- preuve ;
- anomalie associée.

Une inspection du repository ou le comportement supposé de React/Zod n'est pas considéré comme une recette exécutée.

11. C2.3.2 — Correction des bogues

Le registre se trouve dans `docs/rncp/bloc2-plan-correction-bogues-rncp39583.md`. Les défauts découverts le 2026-07-20 y sont traités comme de vraies anomalies : couverture partielle, fixture E2E vide, ownership session-log, invariants IA, Timer, accessibilité, CSP, Docker, CI sécurité, versionnement et incohérences documentaires.

Une anomalie ne passe à « corrigée » qu'après correctif, test de non-régression réussi et preuve rattachée au SHA final.

12. C2.4.1 — Documentation d'exploitation

Document	Rôle
docs/deployment.md	déploiement Vercel, Neon et Docker
docs/ci-cd.md	séquences CI/CD et rollback
docs/rncp/bloc2-manuel-utilisateur-alcide.md	parcours et erreurs utilisateur
docs/rncp/bloc2-manuel-mise-a-jour.md	évolution, migrations, rollback
docs/security/owasp-review.md	revue sécurité et risques résiduels
docs/rncp/bloc2-accessibilite-rgaa.md	référentiel et audit accessibilité
docs/rncp/MANIFESTE-DEPOT-BLOC2.md	contenu et identité de la remise

La procédure Docker utilise des services migrate et seed basés sur le stage builder. Elle ne demande plus d'exécuter drizzle-kit ou tsx dans l'image API de production qui ne les contient pas.

B2-A22 consigne l'exécution locale réelle des deux builds Node 24/pnpm 11.9, des runtimes non-root, de migrate, de seed et du nettoyage ciblé. La CI 29747228594 confirme aussi le build Docker du SHA applicatif final. Le contrôle depuis un clone vierge n'a pas été archivé.

13. État des annexes et preuves résiduelles

Sont acquises et référencées : lint, typecheck, tests, build, PostgreSQL, Playwright public, axe, build Docker, audit de dépendances au niveau Low, CI, CD, healthchecks, démarrage OAuth, recette authentifiée desktop, anomalies et contre-recette, manifeste et PDF contrôlé.

Restent à produire sans les simuler :

- rapports bruts de couverture du SHA déposé, dont une mesure autonome du package shared ;
- instrumentation des écrans Google et suite Playwright authentifiée avec un storageState réel ;
- grille d'audit RGAA humain, captures desktop/mobile associées et lecteur d'écran ;
- rapport de performance final ;
- retour d'un utilisateur autonome ;
- contrôle archivé depuis un clone vierge.

14. Conclusion

Alcide 0.13.0-rc.3 est déployée après CI, migration et CD réussies. Les healthchecks API/Web annoncent cette version, PostgreSQL et la configuration IA sont prêts, l'audit de dépendances ne remonte aucune vulnérabilité connue et la CD n'effectue plus de double production. La recette authentifiée a réellement généré puis supprimé ses données de test et a conduit à quatre corrections contre-recettées. La candidate ne doit toutefois pas être annoncée comme « prête au dépôt sans réserve » tant que l'audit humain RGAA et les contrôles personnels résiduels ne sont pas exécutés.

Cette formulation vise à distinguer ce qui est implémenté, ce qui est prouvé et ce qui reste à exécuter, sans abaisser les critères officiels des compétences éliminatoires.